



Technology Governance Program Guide

Securities and Exchange Commission (SEC)

A complete overview of the Centience governance model built for SEC-regulated organizations.

1. The SEC Governance Imperative

SEC-regulated firms face governance obligations that touch every layer of their technology stack:

- Reg S-P requires a written information security program. Programs require ownership, testing, maintenance, and evidence of operation.
- Investment Adviser cybersecurity proposals would codify annual risk assessments, written policies, incident reporting, and recordkeeping of cybersecurity events.
- SEC examination findings increasingly cite governance failures: policies that exist on paper but are not enforced, risk assessments that are outdated, and incident response plans that have never been tested.
- The Centience model connects policy obligations to technical enforcement through managed infrastructure so your program produces the evidence examiners expect continuously.

2. Phase 1 — SEC Governance Assessment

The assessment establishes your current governance posture against SEC requirements. Scope includes:

- Reg S-P Compliance Review: Written safeguard program evaluation, customer record protection controls, disposal procedures, and breach notification procedures.
- Technology Infrastructure Audit: Endpoint management, encryption status, network segmentation, cloud security posture, and identity and access controls.
- AI and Emerging Technology Review: AI tool inventory, AI governance policy evaluation, and conflict of interest analysis for any AI touching client recommendations.
- Recordkeeping Compliance: Electronic records management, retention configurations, and WORM compliance for applicable records.
- Deliverable: Prioritized risk register with SEC regulatory citation, risk rating, and remediation guidance for each finding.

3. Phase 2 — SEC Governance Roadmap

The roadmap sequences remediation against SEC examination risk. Prioritization is driven by examiner focus areas:

- Critical within 30 days: Active Reg S-P violations including unencrypted customer records, no written safeguard program, and missing incident response procedures.

- High within 90 days: Findings likely to generate examination deficiencies including outdated risk assessment, no annual review documentation, and MFA gaps on customer data systems.
- Medium within 180 days: Governance gaps with indirect examination exposure including incomplete vendor due diligence and missing access reviews.
- Roadmap includes owner, estimated effort, estimated cost, and dependency mapping so foundational infrastructure work precedes policy and documentation work that depends on it.

4. Phase 3 — SEC Ongoing Governance Program

The program phase converts one-time remediation into continuous governance aligned to SEC examination expectations:

- Monthly: Patch status review, access review for privileged accounts, SIEM alert review and disposition, and vendor incident notification monitoring.
- Quarterly: Full access review for customer data systems, governance dashboard update for CCO and senior management, Reg S-P safeguard program review, and vendor due diligence refresh.
- Annually: Full governance assessment refresh, written safeguard program update, penetration test, incident response tabletop with SEC notification timeline testing, and regulatory change management review.
- Examination Support: Maintain standing examination file updated quarterly with full document production support within 24 hours of SEC examination notice.

5. SEC Regulatory Change Management

The SEC amends rules and issues guidance frequently. The governance program includes a regulatory change management process:

- Monitoring: SEC EDGAR rulemaking, SEC examination priorities, Investment Adviser Association and SIFMA regulatory alerts.
- Assessment: Each regulatory change is assessed for applicability, gap impact, and remediation requirements within 30 days of effective date.
- Centience clients receive proactive notice of SEC examination priority changes, new rulemaking with implementation timelines, and enforcement action patterns relevant to their firm profile.

6. SEC Governance Program Readiness Checklist

A mature SEC governance program should be able to demonstrate:

- Written information security program per Reg S-P current and board or senior management approved
- Annual risk assessment completed with documented findings and remediation
- Incident response plan tested within prior 12 months with tabletop results on file
- Vendor due diligence program operational with current files for all critical vendors
- Access reviews completed quarterly with documented evidence of review and remediation
- AI governance policy and inventory current with conflict of interest analysis for client-facing AI
- Regulatory change log with documented response to each material SEC rulemaking
- Standing examination file that can produce all standard examiner document requests within 24 hours

NEXT STEP

Build Your Governance Roadmap

Reading this guide is step one. Step two is knowing exactly where your organization stands and what it takes to close the gaps before a regulator does it for you.

Our assessment delivers a prioritized governance roadmap tailored to your regulatory environment.

WHAT THE ASSESSMENT DELIVERS

- ✓ AI usage discovery across your organization
- ✓ Governance gap analysis by regulatory framework
- ✓ Infrastructure and vendor AI risk review
- ✓ Regulatory exposure analysis (SEC, FINRA, HIPAA)
- ✓ Prioritized governance roadmap
- ✓ Board-ready executive summary
- ✓ Regulatory readiness score by framework

Book Your Assessment →

centience.ai/assessments/financial-services

Call us: (877) 945-7177